

Solidity 最佳实践

- 1) 变量使用驼峰式命名，常量命名字母都大写；事件首字母大写；命名言简意赅（可读性+精简性折中）
- 2) 使用 Solidity < 0.8 时需要使用 SafeMath；Solidity >= 0.8 不需要，它实现了对 math 操作的安全检查
- 3) 代码各要素按照以下顺序出现在合约里：
 - 文件元素布局：SPDX 注释->solidity 版本号->import 语句->外部合约调用接口->使用的 library->合约；
 - 合约内元素布局：类型声明->变量声明->事件->修饰器->函数；
 - 函数元素布局：构造函数->receive 函数->fallback 函数->public 函数->external 函数->internal 函数->private 函数；
 - 函数修饰符布局：可见性->可变性->覆盖性->自定义修饰符；
- 4) 不要在循环里使用 msg.value
- 5) 不要在遍历数组的过程中变更数组的长度
- 6) 迭代中用到的数组，其大小必须确定（动态数组的遍历）
- 7) 尽量使用 mapping 替代动态数组
- 8) 对动态数组调用 pop 操作前，需要确定数组的长度不为 0
- 9) 使用 require 对输入参数进行错误处理
- 10) 使用 revert 对业务逻辑进行错误处理
- 11) 不要在生产环境里使用 assert
- 12) 使用 try/catch 对外部合约函数调用进行错误处理
- 13) 被外部合约调用的函数设置为 external；只被合约内部访问的函数设置为 private
- 14) 当一个函数被继承合约重写时，使用 override 修饰该函数
- 15) private 表示数据不可见，不代表数据的隐私性，不要把隐私数据存放在 private 变量里
- 16) 合约有接受以太坊的需求时，需要实现 receive/fallback payable 函数
- 17) 除了在代理合约中，其余地方不要使用 delegatecall 函数
- 18) 当函数调用有身份验证时，需要使用 openzeppelin 提供的 access 相关合约进行身份管理
- 19) 当需要 payable 时，使用 address.call{value:msg.value}()，而不是 address.transfer() or address.send()
- 20) 函数调用中有外部合约调用时，外部合约接受到的 msg.sender 是合约地址，而不是交易发起者，需要保持对 msg.sender 的敏感性

- 21) 当一个数值可以通过计算获得，同时数值计算花费的 gas 小于数值上链的 gas 时，不要在链上存储这个数值
- 22) 不要使用 tx.origin 来进行身份验证
- 23) 使用 solidity 语法 new 来创建合约，而不是在 assembly 里使用 create2 来创建合约
- 24) 合约里需要对 abi encode 时，使用 abi.encode()来实现
- 25) 使用 keccak256 对数据进行哈希，而不是 sha3
- 26) 函数内部不要修改传入的参数
- 27) 重置数据时，使用 delete 实现
 - a) delete mapping 时，mapping 映射的 value 没有被删除，需要先删除 value 再删除 mapping
- 28) 使用外部调用时，对调用结果成功与否进行验证
- 29) 如果一个合约一定会被其他合约继承，并重新定义该合约的部分函数时，需要把这个合约设置为 abstract 合约
- 30) 关键交易需要触发事件
- 31) public 变量可能被其他合约调用时，不需要自己写 getter 函数，使用编译器自动生成的 getter 函数访问
- 32) 调用 library 的接口时，使用 using A for B 引入需要的数据类型
- 33) 先在接口里声明功能函数，再在合约里实现该接口
- 34) 使用三元运算符简化分支逻辑
- 35) defi 中，solidity 语言没有浮点类型，需要线上线下协同处理好精度问题
- 36) defi 中，不要将 AMM 的现货价格用作预言机（AMM(Automated Market Maker)，使用智能合约实现的区块链网络的自动做市商）
- 37) defi 中，不要在未收到链下或预言机报价的情况下在 AMM 上进行交易
- 38) defi 中，提供完备性检查，防止预言机/价格操纵
- 39) defi 中，确保记录 token 交易时的手续费
- 40) defi 中，使用合约地址持有的初始 token 数量来分配利润时，需要注意：其他地址可以向该合约地址发送 token，从而改变合约地址持有的 token 数量，会造成 token 代币的权益价值的变化
- 41) 完成代码后需要提供单元测试，以及测试说明
- 42) gas 优化的地方需要提供注释说明，说明优化的原理和效果
- 43) unchecked 的地方，需要提供注释说明，保障不会发生上/下溢
- 44) 事件可以作为 DApp 开发的 Trigger，触发跨链、自动执行等操作
- 45) 对外的所有业务接口需要提供注释，包括接口意义，入参、出参等说明